13 Using policy engines with existing systems

This chapter covers

- The evolution of ACME's internal Customer Collaboration platform into the multi-tenant Customer Collaboration Cloud (C^3)
- How a multi-layer authorization model differentiates between platform and tenant responsibilities
- Patterns for deploying policy enforcement points at the gateway, service, and UI levels.
- How the UI uses graph queries and partial evaluation to answer "who or what can access?" questions
- Using a multi-layered policy architecture to allow secure tenant customization

Authorization rarely starts from scratch. Most organizations already have applications, APIs, and data services with authorization embedded in their code or configuration. When organizations adopt a policy engine, the focus isn't on how to start but rather on how to adapt without disrupting existing functions. Integration, rather than invention, presents the true challenge.

ACME Corporation faced this challenge when it transformed its internal Customer Collaboration platform into a commercial SaaS product: the Customer Collaboration Cloud (C^3). The original system was built for internal use, allowing engineers and account managers to share project documents with trusted customers. Over time, its access controls became scattered across controllers, stored procedures, and service endpoints, growing organically. Each team implemented its own version of who-can-see-what, and adding a new rule meant changing the application code in several places.